

Threat Model — PeopleDesk

Platforms: web, cloud | AI capability: llm | Data: Restricted | Expected controls: 29 | PCI in scope: yes

29	4	4	21
Expected	Confirmed in place	Gaps	To verify

Executive summary

PeopleDesk — a web and cloud application with an LLM integration, handling data classified as Restricted — was assessed against the 29 security controls expected for an application of this type (the controls such a system should have in place).

The review confirmed 4 control(s) already in place and identified 4 gap(s) — 2 not implemented and 2 only partially implemented. A further 21 control(s) could not be confirmed from the evidence provided and are flagged for verification — an unconfirmed control is treated as a question to resolve, not a failure.

Confirmed protections include Centralized authentication / SSO, Data-at-rest encryption, and Strong transport encryption (TLS 1.2+); the most important gaps to close are Prompt-injection defense and Data classification applied.

Because the application handles cardholder data, it is in scope for PCI DSS v4.0.1: 2 requirement-mapped control(s) are currently exposed and 9 require verification.

Top threats (by DREAD)

- **[Critical · 7.6]** Prompt-injection defense is not in place (LLM01:2025)
- **[High · 7.0]** Data classification applied is not in place (Control 3)
- **[High · 6.0]** Secure session management is only partial (Control 6)
- **[Medium · 5.2]** Network segmentation / VPC boundaries is only partial (Control 12)

Key gaps to close

- **AI-PI-001** Prompt-injection defense (LLM01:2025)
- **DATA-CLS-001** Data classification applied (Control 3)

Strengths (confirmed in place)

- **IAM-SSO-001** Centralized authentication / SSO
- **DATA-ENC-001** Data-at-rest encryption
- **DATA-TLS-001** Strong transport encryption (TLS 1.2+)
- **WEB-WAF-001** Web application firewall

Also note: 1 compensating control(s) noted (these soften, but do not eliminate, a finding); 21 unknown control(s) need confirmation — treated as clarifications, not findings (unknown ≠ missing).

Control gap register

Control	Status	Frameworks	PCI exposed
AI-PI-001 Prompt-injection defense	Not present	LLM01:2025, Control 16	—
AI-DM-001 Data minimization before model call	Unknown	LLM02:2025, Control 3	—
AI-ENDP-001 No-retention / enterprise model endpoint	Unknown	LLM03:2025, Control 15	—

Control	Status	Frameworks	PCI exposed
AI-OUT-001 Output filtering for sensitive disclosure	Unknown	LLM02:2025, Control 3	—
AI-AUTHZ-001 Authorization scoping on AI features	Unknown	Control 6	—
AI-LOG-001 LLM prompt/response logging	Unknown	Control 8	—
AI-RATE-001 Rate / spend limits on model endpoint	Unknown	LLM10:2025, Control 13	—
AI-VEC-001 Vector store / RAG document-level access control	Unknown	LLM08:2025, LLM02:2025, Control 3	—
AI-MODEL-PROV-001 Model provenance & integrity	Unknown	LLM03:2025, Control 2	—
IAM-SSO-001 Centralized authentication / SSO	Implemented	Control 6	—
IAM-LPA-001 Least-privilege access (RBAC)	Unknown	Control 6	—
DATA-ENC-001 Data-at-rest encryption	Implemented	Control 3	—
DATA-TLS-001 Strong transport encryption (TLS 1.2+)	Implemented	Control 3	—
LOG-AUD-001 Centralized audit logging	Unknown	Control 8	—
DATA-CLS-001 Data classification applied	Not present	Control 3	—
SEC-SECRETS-001 Secrets management	Unknown	Control 6	—
IN-VAL-001 Input validation and output encoding	Unknown	Control 16	—
SCA-SBOM-001 Software composition analysis & SBOM	Unknown	Control 2	—
CLD-SEG-001 Network segmentation / VPC boundaries	Partial	Control 12	1.4.1
CLD-KMS-001 Managed key management (KMS)	Unknown	Control 3	—
CLD-IAM-001 Cloud IAM roles (least privilege)	Unknown	Control 6	—
CLD-SG-001 Restrictive security groups	Unknown	Control 12	—
IMMUT-001 Immutable infrastructure	Unknown	Control 4	—
EDR-001 Endpoint detection & response (EDR) telemetry	Unknown	Control 13	—
WEB-WAF-001 Web application firewall	Implemented	Control 13	—
WEB-CSRF-001 CSRF protection	Unknown	Control 16	—
WEB-SESS-001 Secure session management	Partial	Control 6	8.2.8
WEB-HDR-001 Security response headers	Unknown	Control 16	—
WEB-RATE-001 Request rate limiting	Unknown	API4:2023, Control 13	—

Threat model

ID	STRIDE	Threat	Gap	Maps to
T1	Tampering	Prompt-injection defense is not in place	AI-PI-001	LLM01:2025
T2	InformationDis closure	Data classification applied is not in place	DATA-CLS-001	Control 3
T3	ElevationOfPri vilege	Network segmentation / VPC boundaries is only partial	CLD-SEG-001	Control 12
T4	Spoofing	Secure session management is only partial	WEB-SESS-001	Control 6

Recommendations (gap-closing)

- **Adopt: Prompt-injection defense** (AI-PI-001) — Untrusted text (user fields, retrieved records, tool output) is treated as data, not instructions. Close this gap for an app of this type and data class. *[owasp_11m:LLM01:2025, cis_v8:Control 16]*
- **Adopt: Data classification applied** (DATA-CLS-001) — Data is classified (Public/Internal/Confidential/Restricted) and handled accordingly. Close this gap for an app of this type and data class. *[cis_v8:Control 3]*
- **Strengthen: Network segmentation / VPC boundaries** (CLD-SEG-001) — Workloads are segmented so a compromise does not flatten the network. Close this gap for an app of this type and data class. *[cis_v8:Control 12]*
- **Strengthen: Secure session management** (WEB-SESS-001) — Sessions use secure, HttpOnly, SameSite cookies with sane lifetimes. Close this gap for an app of this type and data class. *[cis_v8:Control 6]*

Mitigations (threat-specific)

- **T1** → Untrusted text (user fields, retrieved records, tool output) is treated as data, not instructions.
- **T2** → Data is classified (Public/Internal/Confidential/Restricted) and handled accordingly. *Partially offset by compensating control(s) tokenization — unverified, not in baseline.*
- **T3** → Workloads are segmented so a compromise does not flatten the network. *Partially offset by compensating control(s) tokenization — unverified, not in baseline.*
- **T4** → Sessions use secure, HttpOnly, SameSite cookies with sane lifetimes.

DREAD scoring

Threat	D	R	E	A	D	Avg	Priority
T1	9	8	8	7	6	7.6	Critical
T2	8	8	6	7	6	7.0	High
T4	7	6	6	6	5	6.0	High
T3	5	6	4	6	5	5.2	Medium

Clarifications needed (unknown ≠ missing)

- Confirm whether 'Least-privilege access (RBAC)' is implemented (Are permissions scoped to least privilege via roles (RBAC) rather than broad/shared access?)
- Confirm whether 'Centralized audit logging' is implemented (Are security-relevant events centrally logged (and retained?)

- Confirm whether 'Secrets management' is implemented (Are secrets stored in a managed secrets vault rather than code/config/client-side?)
- Confirm whether 'Input validation and output encoding' is implemented (Is untrusted input validated and output encoded (injection defenses)?)
- Confirm whether 'Software composition analysis & SBOM' is implemented (Are dependencies inventoried (SBOM) and continuously scanned for known-vulnerable components (SCA)?)
- Confirm whether 'Managed key management (KMS)' is implemented (Are encryption keys managed/rotated via a KMS?)
- Confirm whether 'Cloud IAM roles (least privilege)' is implemented (Do cloud workloads use scoped IAM roles rather than broad static credentials?)
- Confirm whether 'Restrictive security groups' is implemented (Are security-group/firewall rules restrictive (deny by default)?)
- Confirm whether 'Immutable infrastructure' is implemented (Are hosts deployed from versioned images and replaced (not patched in place) with no manual drift?)
- Confirm whether 'Data minimization before model call' is implemented (Is the payload minimized so only necessary fields are sent to the model?)
- Confirm whether 'No-retention / enterprise model endpoint' is implemented (Does the model call go to a no-retention/enterprise endpoint with provider due diligence?)
- Confirm whether 'Output filtering for sensitive disclosure' is implemented (Is model output filtered for sensitive data against the requesting user's clearance?)
- Confirm whether 'Authorization scoping on AI features' is implemented (Is invocation of the AI feature authorized per-record/per-tenant server-side?)
- Confirm whether 'LLM prompt/response logging' is implemented (Are model prompts and responses logged to the audit pipeline?)
- Confirm whether 'Rate / spend limits on model endpoint' is implemented (Are rate and token/spend limits enforced on the model endpoint?)
- Confirm whether 'Vector store / RAG document-level access control' is implemented (Does vector/RAG retrieval enforce per-document/per-user access control (not just relevance)?)
- Confirm whether 'Model provenance & integrity' is implemented (Is the model/weights supply chain verified (trusted source + signing/hash/version pin)?)
- Confirm whether 'Endpoint detection & response (EDR) telemetry' is implemented (Do managed hosts run an EDR/XDR agent feeding telemetry to a monitored detection pipeline?)
- Confirm whether 'CSRF protection' is implemented (Are state-changing requests protected with anti-CSRF tokens?)
- Confirm whether 'Request rate limiting' is implemented (Is request rate limiting enforced at the edge/app?)
- Confirm whether 'Security response headers' is implemented (Are security headers (CSP, HSTS, X-Content-Type-Options) set?)

PCI DSS v4.0.1 compliance view

In scope. Covered PCI-mapped controls: 4.

- **Exposed:** CLD-SEG-001 Network segmentation / VPC boundaries (Partial) → PCI 1.4.1
- **Exposed:** WEB-SESS-001 Secure session management (Partial) → PCI 8.2.8
- **Verify:** IAM-LPA-001 Least-privilege access (RBAC) → PCI 7.2.1
- **Verify:** LOG-AUD-001 Centralized audit logging → PCI 10.2.1
- **Verify:** SEC-SECRETS-001 Secrets management → PCI 8.6.2
- **Verify:** IN-VAL-001 Input validation and output encoding → PCI 6.2.4

- **Verify:** SCA-SBOM-001 Software composition analysis & SBOM → PCI 6.3.2
- **Verify:** CLD-KMS-001 Managed key management (KMS) → PCI 3.6.1
- **Verify:** CLD-IAM-001 Cloud IAM roles (least privilege) → PCI 7.2.1
- **Verify:** CLD-SG-001 Restrictive security groups → PCI 1.3.1
- **Verify:** IMMUT-001 Immutable infrastructure → PCI 2.2.1

Out-of-catalog controls

- Compensating: **tokenization** — Maps to InformationDisclosure; treat as compensating only where it actually applies.
- Candidate: tokenization [InformationDisclosure]